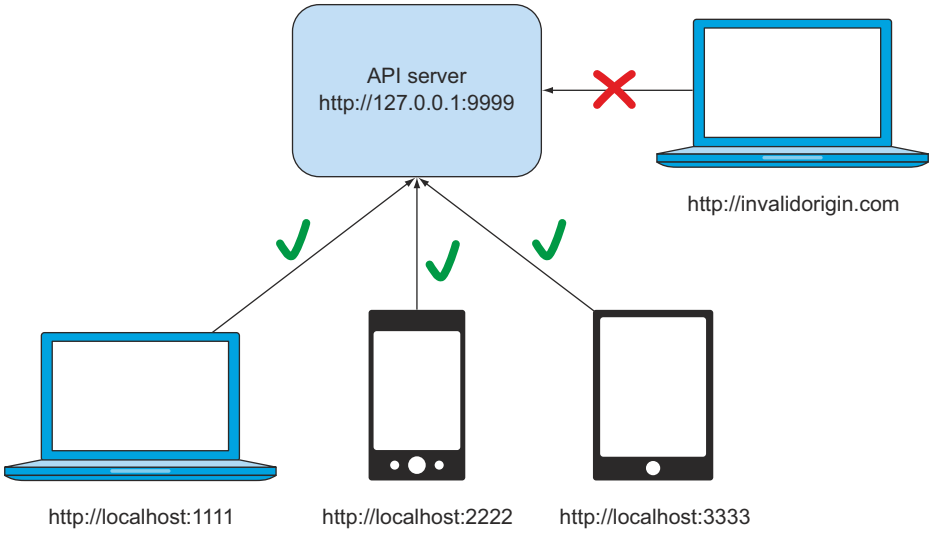


Figure 6.2 Accepting requests from specific origins

for the Access-Control-Allow-Origin header isn't quite right because this could open up your API to unexpected requests.

If you'd like to limit which clients can access your server, the Access-Control-Allow-Origin header also accepts a client origin value. Building off the preceding example, suppose your API is at http://127.0.0.1:9999, and you'd like to allow access to the API from your website at http://localhost:1111, your mobile site at http://localhost:2222, and your tablet site at http://localhost:3333, as shown in figure 6.2.

Chapter 3 showed you how to set the Access-Control-Allow-Origin header to a single origin value. For example, to allow access from a desktop client, the header would be set as

```
Access-Control-Allow-Origin: http://localhost:1111
```

This is fine if you only want to give access to a single origin. But what if instead of only http://localhost:1111, you'd like to give access to a range of origins? Suppose you have mobile, tablet, and web versions of the same website, and you'd like to give them all access to your API. In this case, using a single origin value isn't enough, and the Access-Control-Allow-Origin header doesn't support more than one value. You'll need to write code to process the incoming origin value against a whitelist.

USING A WHITELIST TO SPECIFY THE ORIGIN

A whitelist is a list of origins that are allowed to make requests to the server. In the example from figure 6.2, the whitelist would include the origins http://localhost:1111, http://localhost:2222, and http://localhost:3333. If the origin of the incoming request matches one of these values, then the client is allowed access to the resource.

The code in the following listing creates a function to validate an origin value against a whitelist.